



המשכיות עסקית - המשך



Disaster Recovery Plan

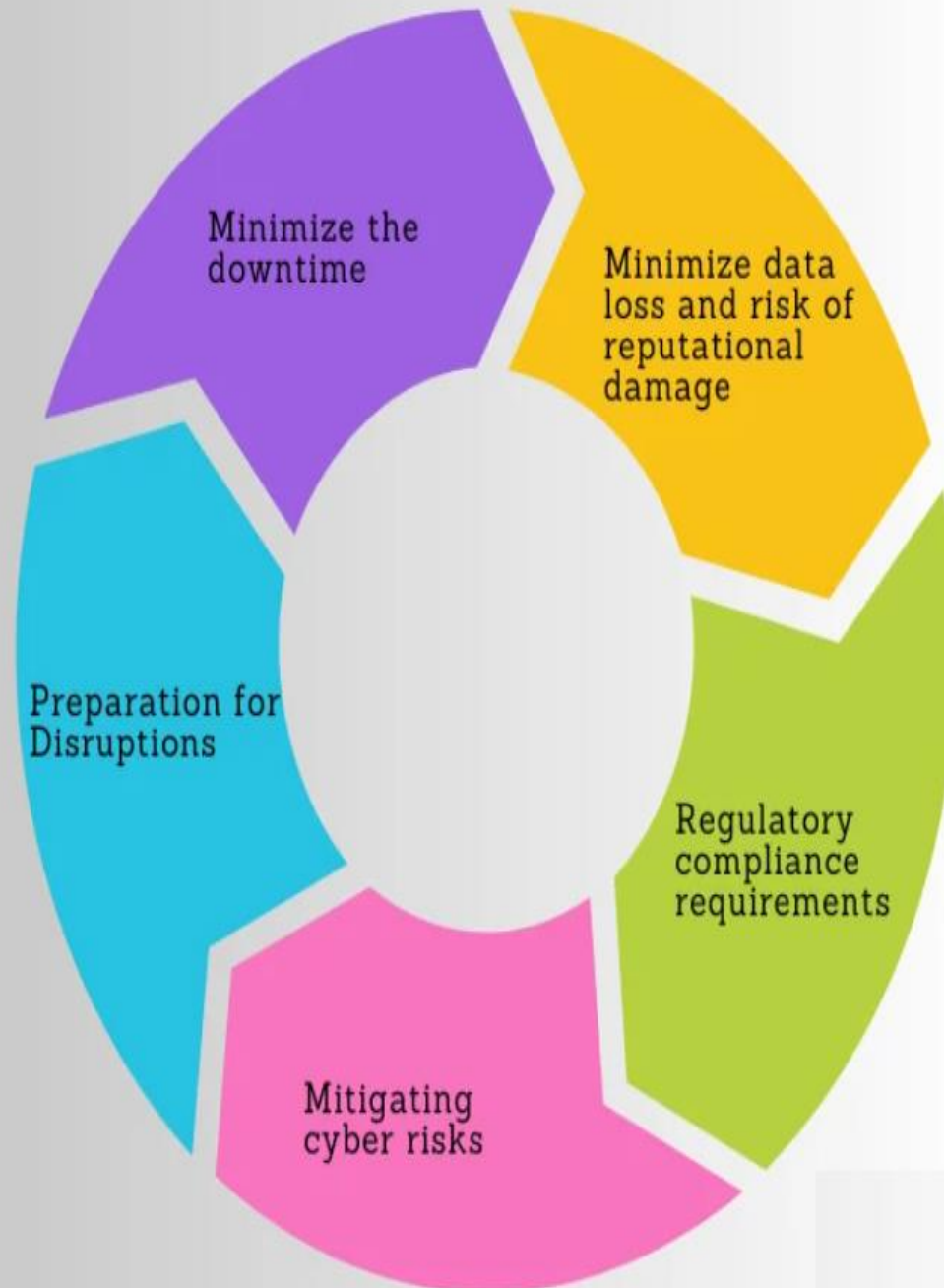
MINIMIZE THE
DOWNTIME

MINIMIZE DATA
LOSS

COMPLIANCE
REQUIREMENTS

MITIGATING
CYBER RISKS

PREPARATION
FOR DISRUPTIONS



Disaster Recovery Plan (DRP) בעולמות הסייבר

- צמצום למינימום (או ל 0) זמן "מת" של מערכת
- צמצום למינימום (או ל 0) איבוד מידע
- עמידה בתקנים המחייבים אבטחת מידע ותקני התאוששות
- מערכות בהתאם ל (IEC 27001 ו IEC 62443)
- ניהול תוכנית סיכונים ותוכנית גיבוי
- הכנה / מוכנות - לשינויים / תקלות / תרחישים לא צפויים

Disaster Recovery Plan (DRP) בעולמות הסייבר



High Level Cyber Incident Response process - Incident Response Plan



- SEMT – Senior Executive Management Team
- CSIRT - Computer Security Incident Response Team
- RCA – Root Cause Analysis



תוכנית תקשורת

• הקימו ערוצי תקשורת ברורים לבעלי עניין פנימיים וחיצוניים כדי לספק מידע מדויק בזמן המתאים במהלך משבר.

• SLACK

• WEBEX

• WIKI

• SHAREPOINT

• כול מקום עבודה משותף שאפשר לעבוד בו

• הגדרת הרשאות גישה

• קביעת פגישות סדירות ונהלי עבודה

• מיפוי ורתימה של כול בעלי המניות בארגון

• בחירה וניהול של כלים נכונים

• תקשורת להנהלה ולעובדי הארגון

• בניית פורומים פנים וחוץ ארגנים (לא מעורבים ברוב המקרים)

Your Personal files are encrypted !!!

Private key will
be destroyed in:

Time Left

71:59:59

חרגיל

חרגיל

חרגיל



תרגול תקופתי (Tabletop & Live Exercises) בהתאם לתקני המערך הדיגיטלי הלאומי

- תרגול תקופתי כאשר הנחיית התקשוב היא קיים זאת לפחות כל 18-24 חודשים בהשתתפות משקיף / צוות בקרה בלתי תלוי שיבחן את התרגול וידווח על התרשמותו, תיעוד תוצאות התרגול, הפקת לקחים ועדכון יעדי השירות והתכנית להמשכיות עסקית ותפקודית בהתאם.
- החברה תגבש תכנית תרגול תקופתית הכוללת את כלל התרחישים ואת התהליכים הקריטיים הכלולים בתוכנית להבטחת ההמשכיות העסקית והתפקודית.
- החברה תערוך תרגיל מעשי ומקיף, בהשתתפות משקיף / צוות בקרה שייבחן את המוכנות לחירום של האגף.
- הנוהל המחייב הוא ביצוע 3 תרגילים כאלה בכל שנת עבודה.

מערך הדיגיטל הלאומי
نظام الديجيتال الوطني
Israel National Digital Agency



תרגול תקופתי (Tabletop & Live Exercises) בהתאם לתקני המערך הדיגיטלי הלאומי

- הפקת לקחים – כל תרגיל יתוחקר ויילמד על פי הנחית מערך הדיגיטל בנושא תחקור והפקת לקחים. מסקנות התרגיל יועברו להנהלת המשרד ללימוד ובחינת עדכונים נדרשים בתוכנית להבטחת המשכיות העסקית והתפקודית.
- הקמה, הפעלה ותרגול חדר מצב - האגף יפעיל "חדר מצב" (פיזי או וירטואלי) הכולל את כל האמצעים הנדרשים לניהול המצב, כולל אמצעי תקשורת חלופיים בשיטה שבה לא תהיה נקודת כשל אחת (SINGLE NO FAILURE OF POINT) שתשבש את פעולת "חדר המצב". "חדר המצב" ישמש את המנהלים ואנשי המקצוע של האגף הרלבנטיים לניהול מצב החירום ולהפעלת תכנית הפעולה להמשכיות עסקית ותפקודית



תקן ISO 22301

• תקן ISO 22301 מתאים לארגונים מכל הגדלים והסוגים המעוניינים להקים מערכת לניהול המשכיות עסקית במצבי משבר וחירום, כגון:

- מלחמה
- שריפה
- מתקפות טרור / סייבר
- מתקפת סחיטה / כופר
- מפגעי טבע (רעידת אדמה, צונמי, סופות, הצפות)
- נפילת ספקי שירות (חשמל, תקשורת)
- אירועים אקלימיים בעלי השלכות גלובליות



למה להטמיע את תקן ISO 22301 ?

- צמצום עלויות בעזרת הערכות מוקדמת להמשכיות עסקית בעת מצבי חירום.
- יישום שיטה אחידה וברורה המעמידה את החברות בארץ בקו אחד עם תקנים יוקרתיים ומוערכים בעולם.
- זיהוי איומים לפעילויות קריטיות של הארגון, עמידות הארגון באיומים ומניעתם.
- היערכות למצב של פגיעה בפעילות עסקית.
- המשך הפעילות במצב לא צפוי במינימום פעילות עסקית נדרשת.
- צמצום בפגיעה במוניטין (כמתחייב מהחוזים ומנתח השוק שעליו הארגון מעוניין לחלוש).
- מענה לדרישות רגולטוריות או סטטוטוריות המחייבות את הארגון.



כלים טכנולוגיים למזעור נזקים

מערכות ניטור



זיהוי בזמן אמת של חריגות ואנומליות. שליחת התראות מיידיות לצוות האבטחה.

הגנה מבוססת AI



אלגוריתמים חכמים לזיהוי איומים מתקדמים. למידת דפוסי התקפה חדשים באופן אוטומטי.

בדיקות חוסן



סימולציות תקיפה לאיתור פרצות. דימוי מתקפות מתוחכמות לבחינת מוכנות הארגון.

CISCO

FORTINET

CHECK POINT



Microsoft

Akamai

paloalto
NETWORKS

McAfee

IBM

Symantec
Endpoint Protection

מדידה והערכה

סוג המדידה	תדירות	אחראי ביצוע
תרגולות חירום	רבעוני	צוות SOC
סקרי סיכונים	חצי שנתי	מנהל אבטחת מידע
ביקורת BCP	שנתי	מבקר חיצוני
סימולציות תקיפה	רבעוני	צוות – Red Team Response Tea





סיכום: חשיבות BCP בעידן הדיגיטלי

60%

הפחתת עלויות

חיסכון בעלויות אירוע סייבר בזכות היערכות מוקדמת

85%

מוכנות כיתרון תחרותי

ארגונים עם BCP מתאוששים מהר יותר מאירועי סייבר

X3

אמון לקוחות

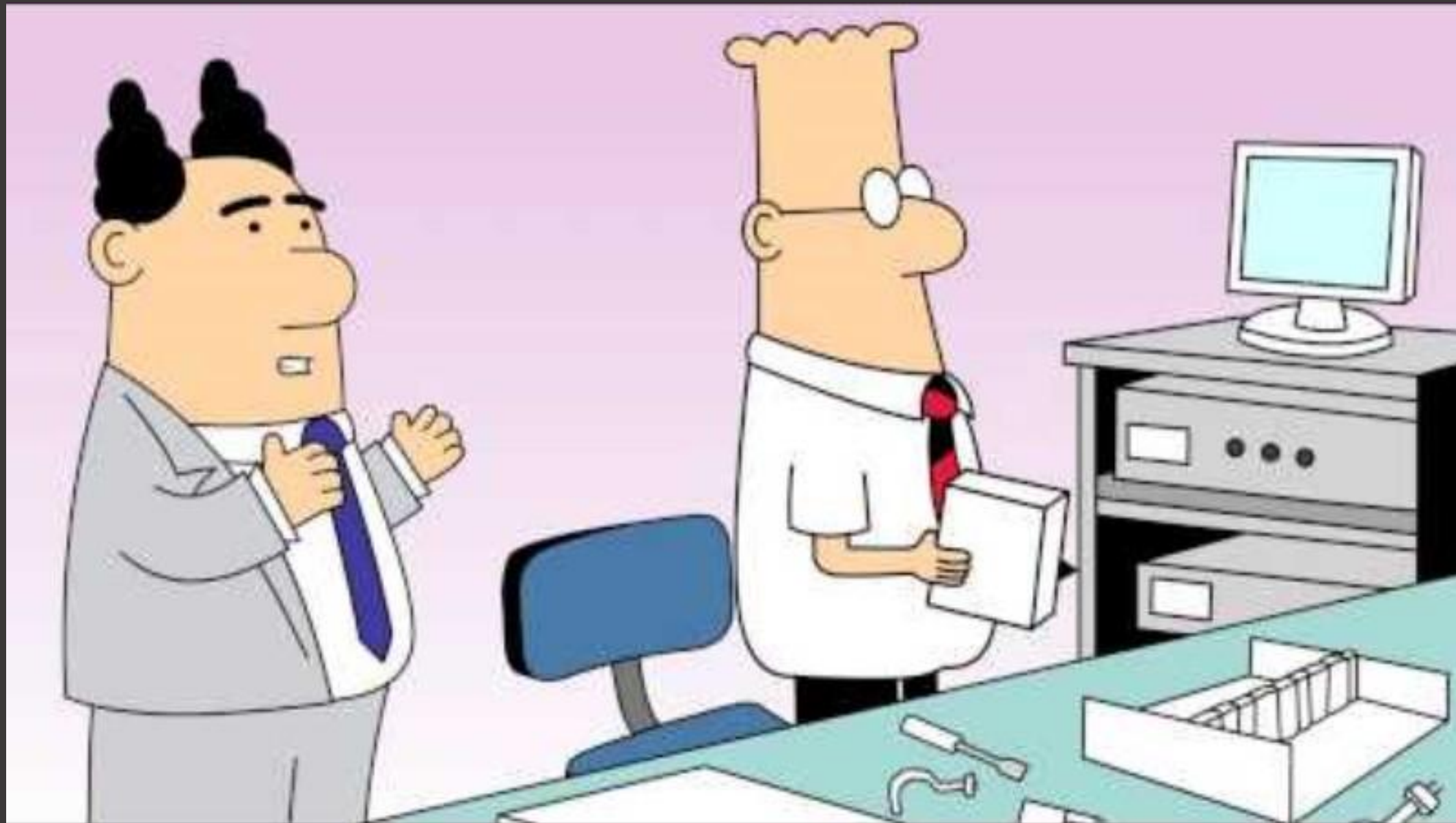
שיפור בשימור לקוחות בארגונים עם תוכנית התאוששות



בניית תקציבים בניהול הגנת סייבר

הגנה מפני איומי סייבר דורשת תקציב מוגדר ומדויק. פריצות סייבר עולות מיליארדי דולרים מדי שנה.

איך בונים תקציב...



מי צריך תקציב ובשביל מה .. כן כן עוד פעם מיפויים ?

זיהוי נכסים	הערכת סיכונים	קביעת סדרי עדיפויות
מיפוי הנכסים הקריטיים לארגון כגון נתונים ומערכות מפתח.	• זיהוי נכסים קריטיים (מערכות, מידע, שירותים). • הערכת פגיעויות קיימות וסבירות לאיומים שונים (כופר, פשינג, חדירה פנימית). • תעדוף לפי השפעה עסקית – ROI של כל שלב מונע.	הגנה בהתאם לרמת הסיכון ומשאבים זמינים, כמובן שהם יכולים להשתנות.

מדיניות ורגולציות

- עמידה בתקנים רגולטוריים כגון: ISO 27001, GDPR, PCI-DSS
- תחזית עלות עמידה בתקנות והשלכות כספיות על אי-ציות.

רכיבים מרכזיים בתקציב הגנת סייבר

תוכנות אנטי וירוס ואנטי-מלואר

עלויות רישוי ועדכונים שוטפים חובה לכל מערכת.

כלים לניתוח התנהגויות

ניהול זהויות, הצפנה, סימולטורים

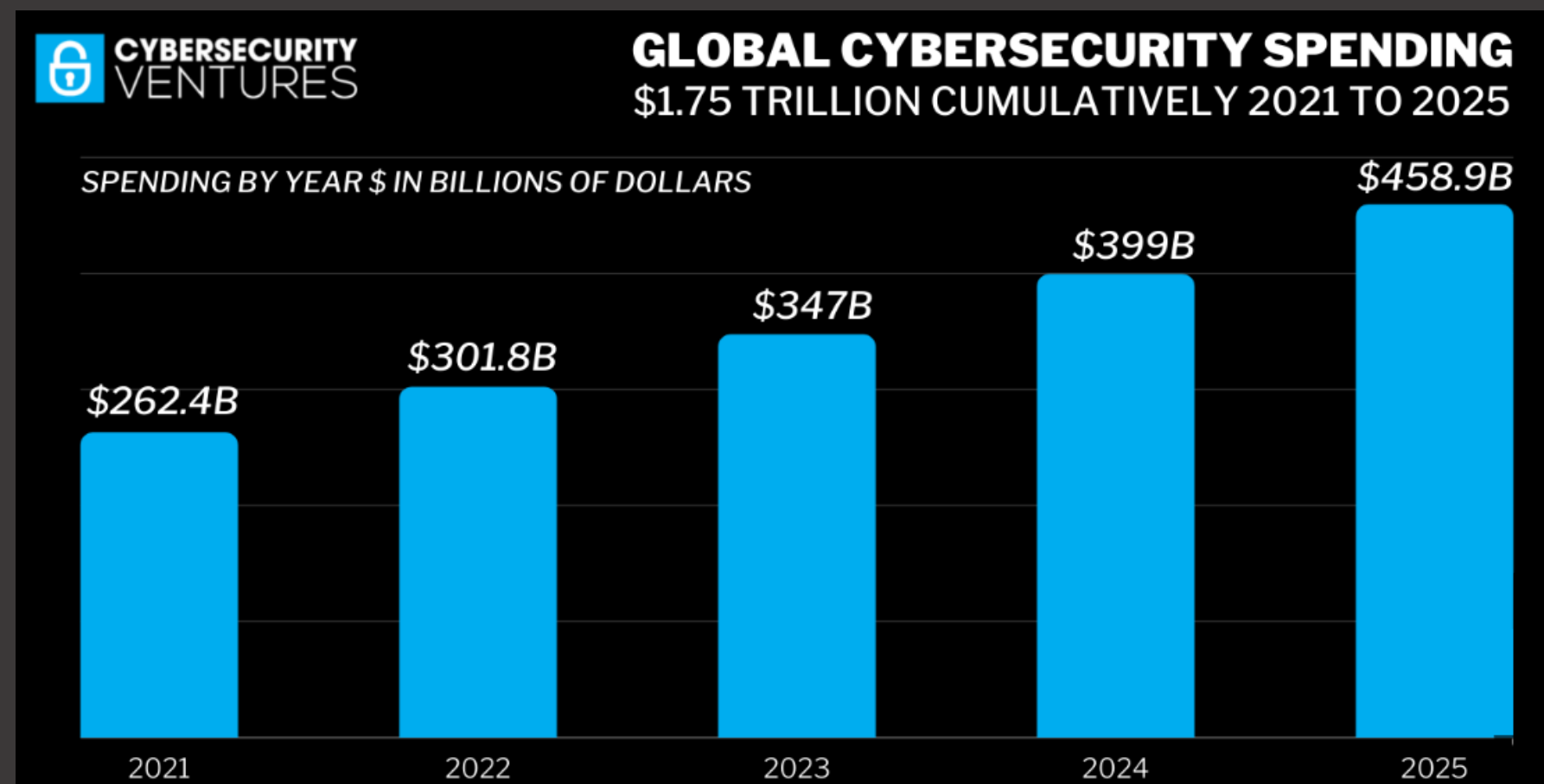
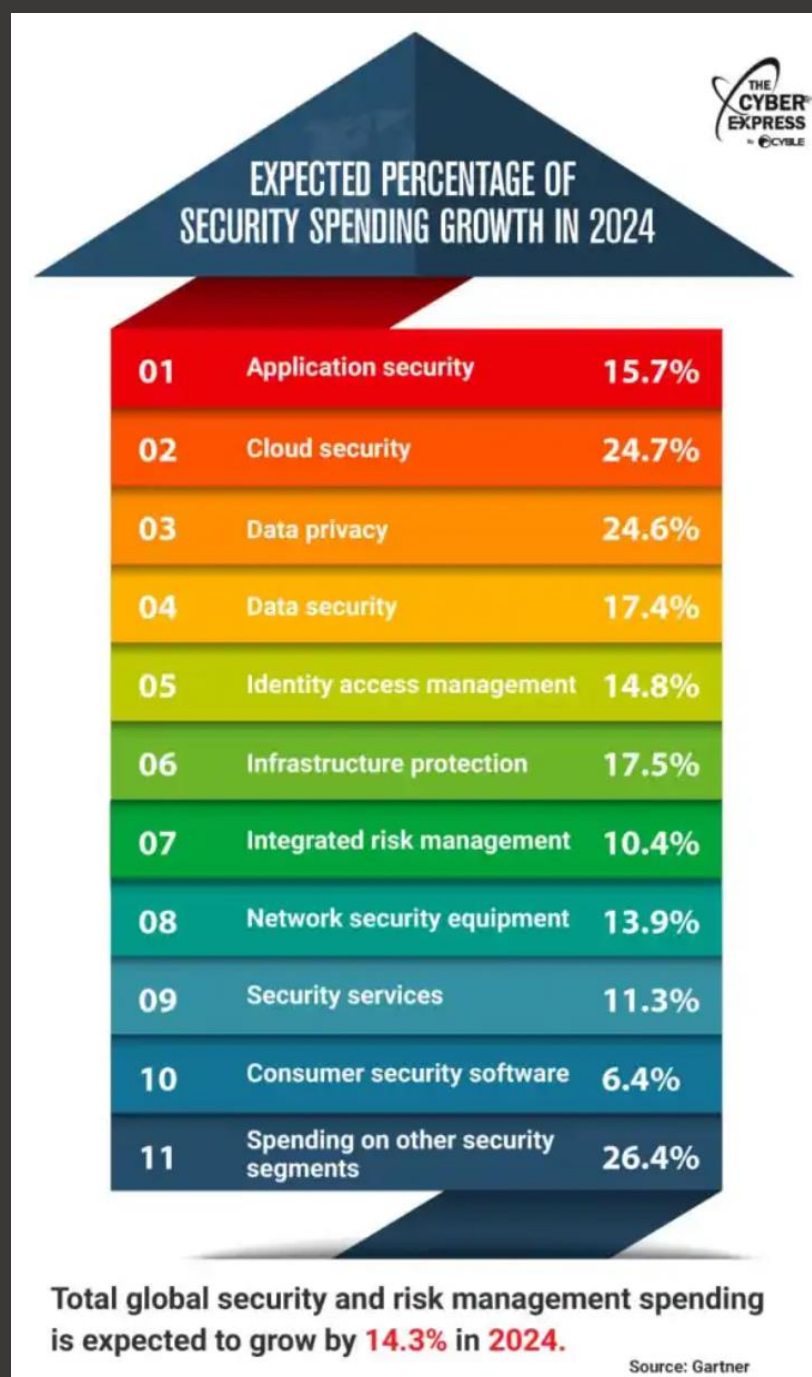
מערכות IDS ו IPSI (Intrusion Detection System ,Intrusion Prevention System)

זיהוי ומניעת פריצות בזמן אמת, מערכות SIEM ,DLP ,IAM ,EDR

,DATA LOSS PREVENTION ,SECURITY INFORMATION AND EVENT MANAGEMENT

END POINT DETECTION AND RESPONSE ,IDENTITY AND ACCESS MANAGEMENT

נוסיף קצת מספרים...





מה קורה בארץ ? כמה חברות מתקצבות לאבטחת מידע ?

- חברות קטנות (10–50 עובדים)
 - הוצאה שנתית ממוצעת: 350,000–700,000 ₪
 - עלות ממוצעת לעובד: 7,000–14,000 ₪
 - אחוז מההכנסות: 2.8%–4.2%
- חברות בינוניות (51–200 עובדים)
 - הוצאה שנתית ממוצעת: 800,000–2,500,000 ₪
 - עלות ממוצעת לעובד: 12,000–18,000 ₪
 - אחוז מההכנסות: 3.5%–5.5%
- חברות גדולות (מעל 200 עובדים)
 - הוצאה שנתית ממוצעת: 3,000,000 ש"ח ומעלה
 - עלות ממוצעת לעובד: 15,000–25,000 ₪
 - אחוז מההכנסות: 4%–7%

וכמה כופר שילמנו ?

In 2024, ransomware attackers received approximately **\$813.55 million** in payments from victims.



Any Questions?
Please don't feel afraid to ask.